

OPERATION SHADOW VAULT

Reporte Ejecutivo de Red Team

Clasificacion:	CONFIDENCIAL — Uso educativo
Adversario simulado:	APT28 (Fancy Bear) — GRU Rusia
Objetivo:	atackcorp.local — WKSTN-01
Fecha:	06 Junio 2026
Operador:	Adrian Camacho
Estado:	COMPLETADO — 4/5 Fases (Fase 03 bloqueada por KPP)

1. Resumen Ejecutivo

SHADOW VAULT demostro que la workstation corporativa WKSTN-01 puede comprometerse completamente partiendo de credenciales de helpdesk de bajo privilegio, sin explotar vulnerabilidades de software. El vector principal fue una misconfiguracion de permisos LAPS que exponia la contrasena del Administrador local via LDAP, combinada con la capacidad de descifrar credenciales DPAPI almacenadas offline.

Adicionalmente, el abuso de WriteDACL sobre el objeto de computadora WKSTN-01 permitio el ataque Shadow Credentials, obteniendo el NT hash de la cuenta de maquina. Se establecio persistencia mediante beacon Sliver HTTPS como Administrador local.

Attack Path

Paso	Tecnica	Resultado
1	LAPS Password Disclosure (nxc ldap -M laps)	WKSTN-01\Administrador : @98q6\$13Z{K99;
2	DPAPI offline — impacket-dpapi	sa:SQLsa2026! + helpdesk.ruiz:Helpdesk2024!
3	LSASS Dump (comsvcs.dll MiniDump)	BLOQUEADO — Windows 11 23H2+ KPP
4	Shadow Credentials (pywhisker + certipy-ad)	WKSTN-01\$ NT hash: 5bcb127196e1fd7cc35e3d62066cabe3
5	C2 Sliver HTTPS beacon	Persistencia como Administrador local

2. Crown Jewels Capturados

#	Objetivo	Resultado	Impacto
1	msLAPS-Password WKSTN-01	Administrador : @98q6\$13Z{K99;	CRITICO
2	DPAPI — Credential Manager sa	sa : SQLsa2026! (DC-01\SQLEXPRESS)	CRITICO
3	DPAPI — Credential Manager helpdesk	helpdesk.ruiz : Helpdesk2024!	ALTO
4	Shadow Credentials WKSTN-01\$	NT hash: 5bcb127196e1fd7cc35e3d62066cabe3	ALTO
5	Beacon C2 en WKSTN-01	SUPPORTING_NECKLACE — Administrador	ALTO

3. Fases de la Operacion

Fase 01 — LAPS Password Extraction [T1201 / T1078.003]

nxc ldap 10.0.2.10 -M laps confirmo que helpdesk.ruiz tenia permisos de lectura directa sobre msLAPS-Password de WKSTN-01. La contraseña del Administrador local fue obtenida en texto claro via LDAP. WS2025 usa cifrado GKDI por defecto — requirio deshabilitar ADPasswordEncryptionEnabled para que las herramientas Linux pudieran leer el atributo.

Fase 02 — DPAPI Credential Extraction [T1555.004]

Con acceso de Administrador local via credencial LAPS, se extrajeron los blobs DPAPI de helpdesk.ruiz del sistema de archivos. impacket-dpapi descifro la Master Key usando la contraseña del usuario y extrajo dos credenciales: helpdesk.ruiz:Helpdesk2024! (portal-it) y sa:SQLsa2026! (DC-01\SQLEXPRESS). El descifrado se realizo completamente offline desde Kali.

Fase 03 — LSASS Dump sin Mimikatz [T1003.001] — BLOQUEADO

rundll32.exe comsvcs.dll MiniDump fue bloqueado en Windows 11 23H2+ (Build 26100). Incluso con RunAsPPL=0 y Defender deshabilitado, Kernel Patch Protection impide el acceso a LSASS. Isassy (comsvcs/wmi/task/mmc), Task Manager dump y Process.Start tambien bloqueados. Requiere tecnicas avanzadas BYOD/kernel exploit — cubiertas en Labs 08-11.

Fase 04 — Shadow Credentials [T1649]

helpdesk.ruiz tenia WriteDACL sobre el objeto WKSTN-01 en AD. pywhisker aniadio un certificado malicioso a msDS-KeyCredentialLink. certipy-ad autentico via PKINIT con el certificado PFX obteniendo un TGT y el NT hash de WKSTN-01\$ (5bcb127196e1fd7cc35e3d62066cabe3). Shadow Credential eliminada tras obtener el hash.

Fase 05 — C2 + OPSEC Cleanup [T1071.001 / T1070.004]

Beacon Sliver HTTPS SUPPORTING_NECKLACE desplegado en WKSTN-01 como Administrador local. OPSEC cleanup completo: beacon eliminado del disco tras detener el proceso, credenciales DPAPI eliminadas de C:\Temp, historial PowerShell limpiado.

4. MITRE ATT&CK; Coverage

Tactica	Tecnica	ID	Estado
Discovery	Password Policy Discovery	T1201	OK
Credential Access	Credentials from Password Stores: WCM	T1555.004	OK
Credential Access	OS Credential Dumping: LSASS	T1003.001	BLOQUEADO
Credential Access	Steal/Forge Auth Certificates	T1649	OK
Privilege Escalation	Valid Accounts: Local Accounts	T1078.003	OK
Lateral Movement	Remote Services: SMB	T1021.002	OK
Command & Control	App Layer Protocol: Web	T1071.001	OK
Defense Evasion	Indicator Removal: File Deletion	T1070.004	OK

5. Hallazgos Criticos y Recomendaciones

H-01 — LAPS permisos de lectura excesivos [CRITICO]

Descripcion: helpdesk.ruiz tenia permisos de lectura sobre msLAPS-Password de WKSTN-01, exponiendo la contrasena del Administrador local a cualquier cuenta de helpdesk comprometida.

Recomendacion: Revisar y restringir permisos LAPS. Solo grupos de Tier 1 deben leer passwords de workstations. Habilitar cifrado GKDI (ADPasswordEncryptionEnabled=1) en produccion.

H-02 — DPAPI: credenciales en Credential Manager [ALTO]

Descripcion: Credenciales de SQL Server SA almacenadas en el Credential Manager de helpdesk.ruiz fueron descifradas offline con acceso de Administrador local.

Recomendacion: GPO: deshabilitar almacenamiento de contraseñas de red. Usar Credential Guard. No almacenar credenciales privilegiadas en cuentas de helpdesk.

H-03 — WriteDACL sobre objeto computadora [ALTO]

Descripcion: helpdesk.ruiz tenia WriteDACL sobre WKSTN-01 en AD, permitiendo el ataque Shadow Credentials para obtener el NT hash de la cuenta de maquina.

Recomendacion: Auditar WriteDACL en objetos de computadora. Implementar alertas en Event ID 5136 para cambios en msDS-KeyCredentialLink.

H-04 — Administrador local accesible via LAPS [MEDIO]

Descripcion: Una vez obtenida la contraseña LAPS, el Administrador local permitio acceso SMB C\$ completo y ejecucion de binarios en la workstation.

Recomendacion: Network segmentation para limitar SMB entre workstations. EDR con deteccion de movimiento lateral.

6. Lecciones Aprendidas (seleccion)

L-01: WS2025 LAPS y cifrado GKDI: msLAPS-EncryptedPassword usa GKDI — ninguna herramienta Linux lo descifra en 2026. Requiere deshabilitar ADPasswordEncryptionEnabled via GPO o registro para ataques desde Kali.

L-02: Evil-WinRM = Network Logon (tipo 3): cmdkey no puede leer/escribir en Credential Manager. rundll32 comsvcs.dll MiniDump falla por falta de SeDebugPrivilege. En engagement real: usar RDP o beacon en contexto usuario.

L-03: LSASS dump bloqueado en Windows 11 23H2+: RunAsPPL=0 requiere reinicio. Incluso con PPL=0 + Defender OFF, Kernel Patch Protection bloquea acceso a LSASS. Task Manager dump también bloqueado. Requiere BYOD/kernel exploit.

L-04: pywhisker requiere --use-ldaps en WS2025 (LDAP signing enforced). Usar certipy-ad v5.0.4 — conflicto con python3-certipy en Kali.

L-05: Evil-WinRM no descarga archivos con atributos -hs- (sistema+oculto). Usar impacket-smbclient para extraer blobs DPAPI.

L-06: nxc smb con Administrador local genera NETBIOS timeout. Usar impacket-smbclient './Administrador:pass@IP' para acceso SMB con cuenta local.

L-07: El firewall de Windows 11 se reactiva tras cada reinicio. Solución definitiva: Set-NetFirewallProfile -Enabled False en el script de provisioning.

L-08: DPAPI funciona completamente offline: extraer blobs del sistema de archivos como Administrador local y descifrar en Kali con impacket-dpapi — no requiere sesión interactiva del usuario.